

Lab Report 4 - Cybersecurity Analytics

Analyze Captured Network Traffic Using Network Miner

Introduction

This lab is designed to work with VM machines to get practical skills of analyzing captured traffic using Network Miner and confirm the analysis by using Wireshark. Here, we are going to analyze *file_lab4.pcap* pcap file to identify hosts, ports and attack evidence. This lab is a part of our previous lab which we used the *file_lab2.pcap* pcap file to analyze traffic and detect the Distributed Denial of Service (DDoS) using HTTP GET request. Analyzing packet captures provides investigators with valuable indicators of compromise, allowing them to trace attacker behavior through the different stages of an attack lifecycle (Easttom, 2022).

According to Shostack (2014), traffic analysis can be mapped to the Lockheed Martin Cyber Kill Chain, showing how adversaries transition from reconnaissance to exploitation. NIST SP 800-30 provides Guide for conducting Risk assessments and NIST SP 800-37 provides Risk management framework for information systems and organizations. NIST SP 800-53 provides Security and privacy controls for information systems and organizations. This lab gives practical analysis skills and how traffic evidence is used to bank network risk management processes.

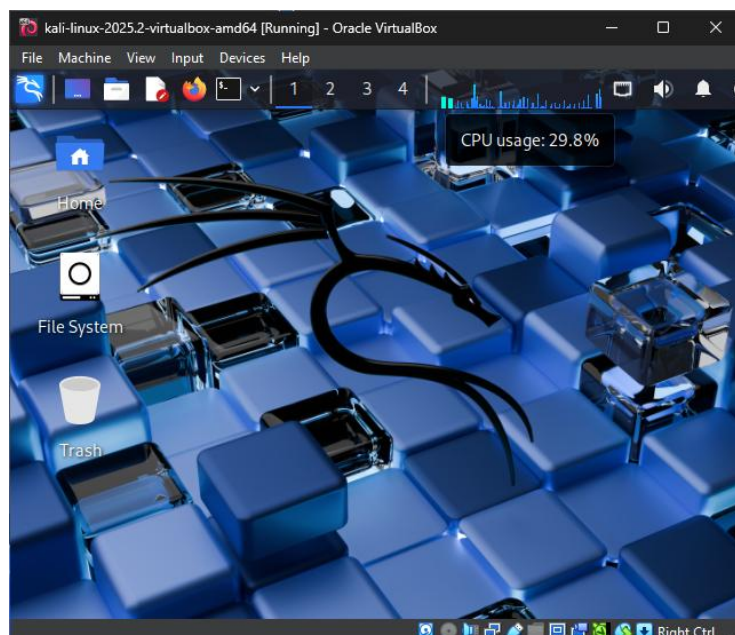
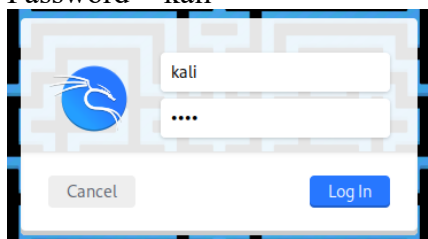
Part - 1

1. Logged to Azure Lab environment using following web link and logged into the Kali VM using Oracle VirtualBox.

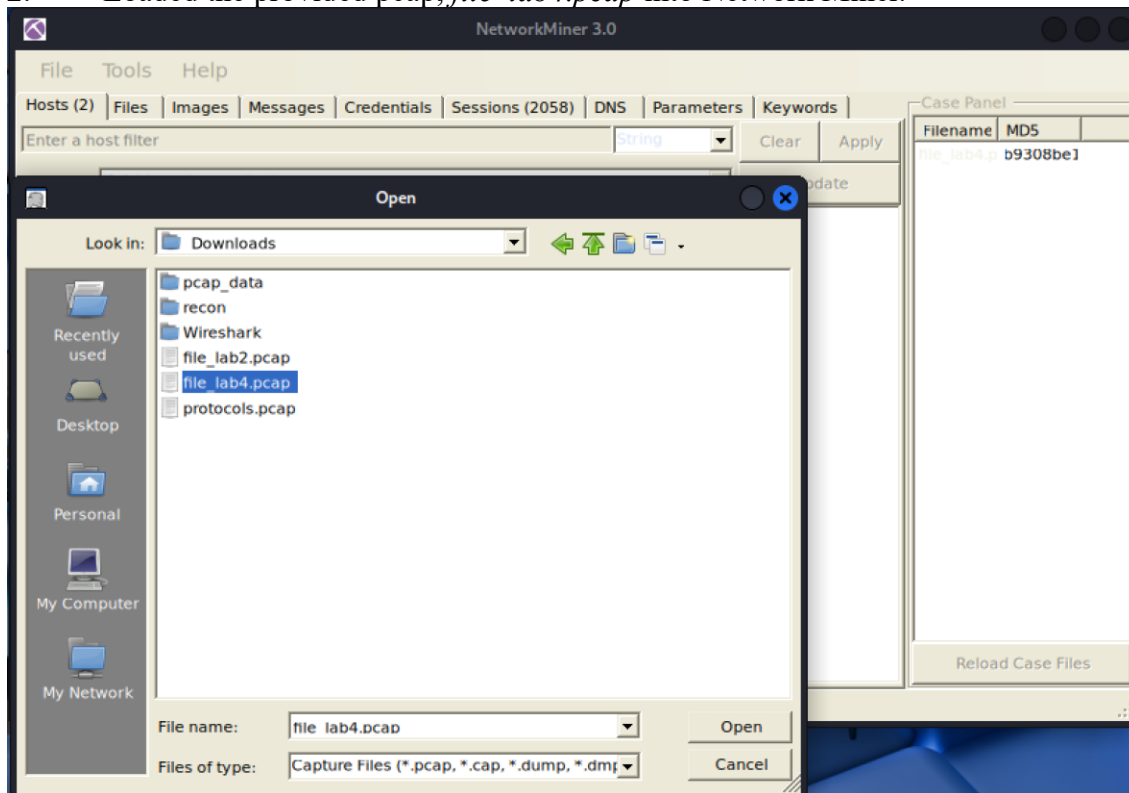
https://labs.azure.com/virtualmachines?feature_vnext=true

Username - kali

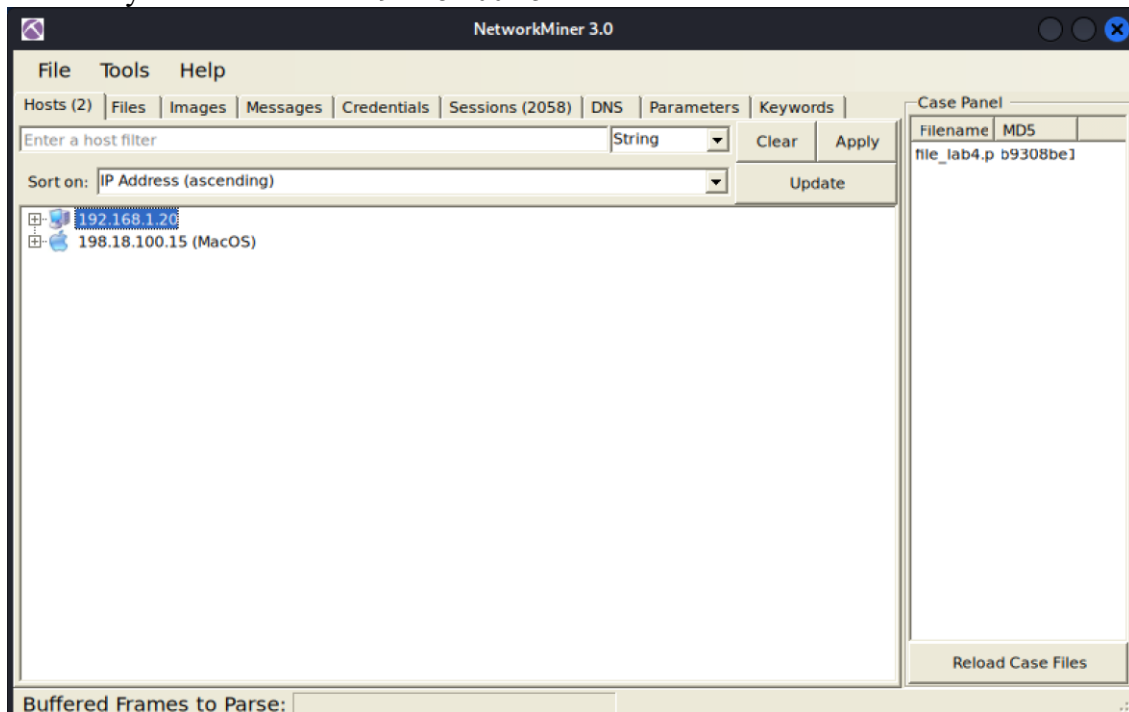
Password - kali



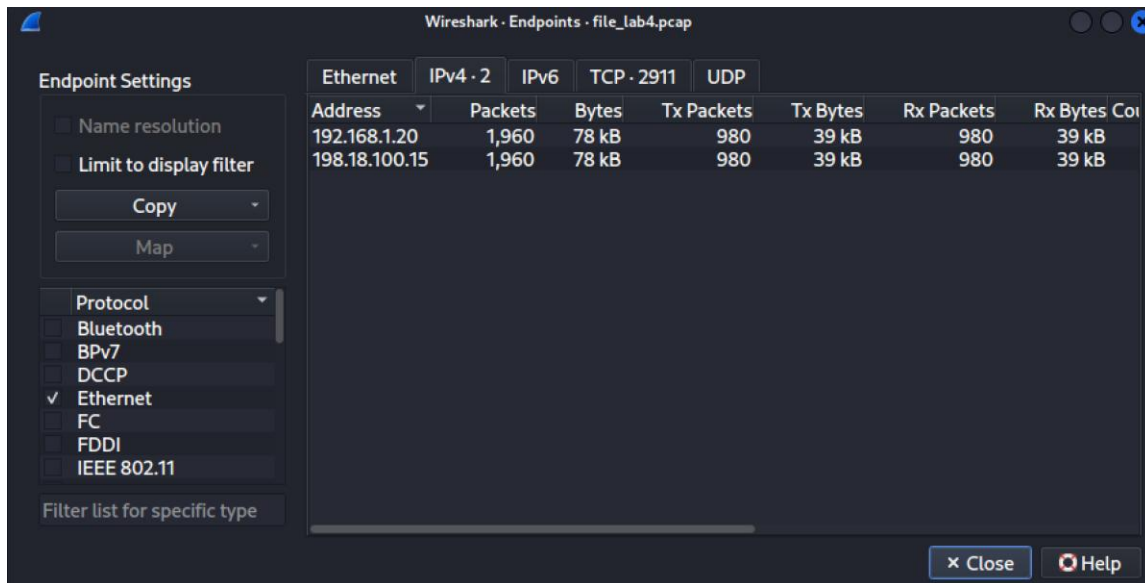
2. Loaded the provided pcap, *file lab4.pcap* into Network Miner.



3. In the Network Miner *Hosts* tab, two IPv4 addresses were detected. 192.168.1.20 is internal host likely workstation and 192.18.100.15 external host with Mac OS.

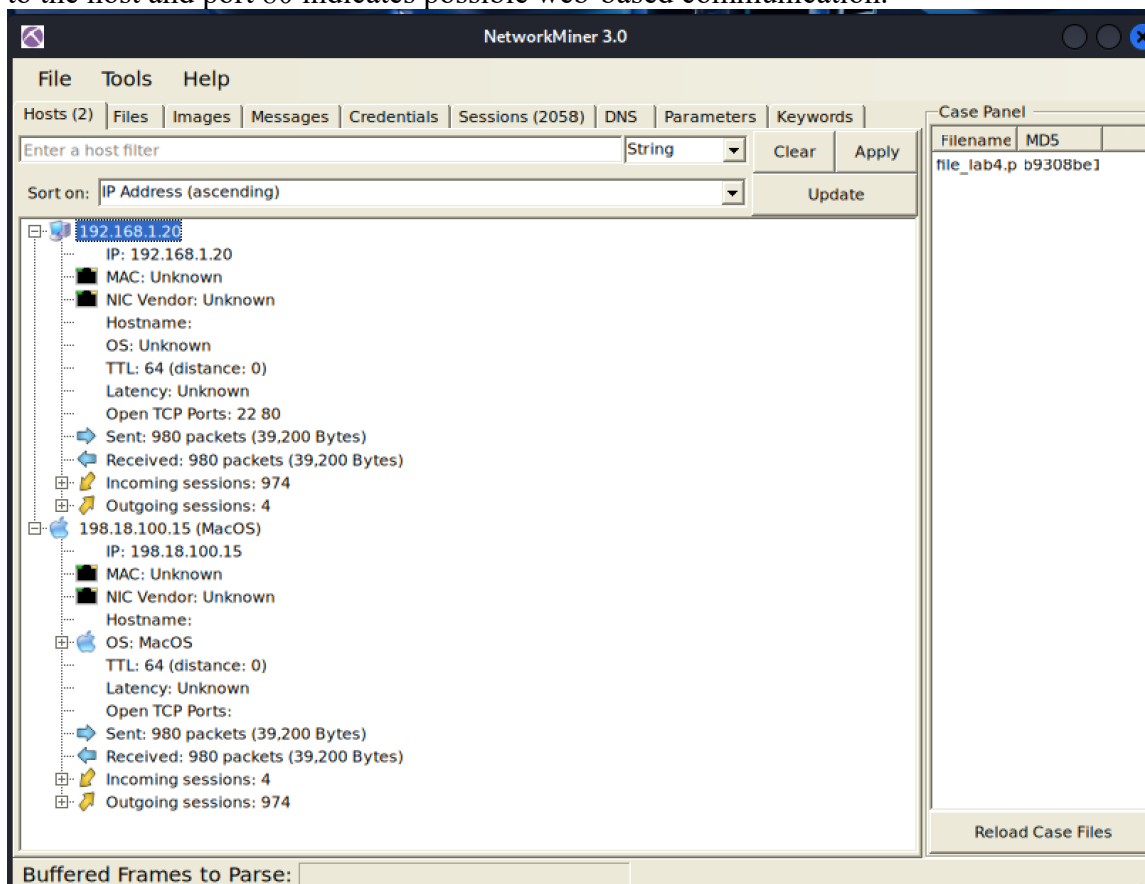


3. Verified the IPv4 addresses detected from Network miner using Wireshark under *Statistics, All Addresses* or we can use *Statistics, Endpoints*. This displayed both IPv4 addresses with active TCP communications.



Wireshark - Endpoints - file_lab4.pcap							
Endpoint Settings							
☐ Name resolution ☐ Limit to display filter Copy Map Protocol ☐ Bluetooth ☐ BPv7 ☐ DCCP ☒ Ethernet ☐ FC ☐ FDDI ☐ IEEE 802.11 Filter list for specific type							
Ethernet	IPv4 - 2	IPv6	TCP - 2911	UDP			
Address	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Count
192.168.1.20	1,960	78 kB	980	39 kB	980	39 kB	
198.18.100.15	1,960	78 kB	980	39 kB	980	39 kB	

4. The Network Miner filtered that TCP ports 22 (SSH) and 80 (HTTP) as open ports and active on 192.168.1.20. Port 22 indicated the possible attempt to establish or exploit remote access to the host and port 80 indicates possible web-based communication.



NetworkMiner 3.0

File Tools Help

Hosts (2) | Files | Images | Messages | Credentials | Sessions (2058) | DNS | Parameters | Keywords

Enter a host filter: String

Sort on: IP Address (ascending)

192.168.1.20

- IP: 192.168.1.20
- MAC: Unknown
- NIC Vendor: Unknown
- Hostname:
- OS: Unknown
- TTL: 64 (distance: 0)
- Latency: Unknown
- Open TCP Ports: 22 80
- Sent: 980 packets (39,200 Bytes)
- Received: 980 packets (39,200 Bytes)
- Incoming sessions: 974
- Outgoing sessions: 4

198.18.100.15 (MacOS)

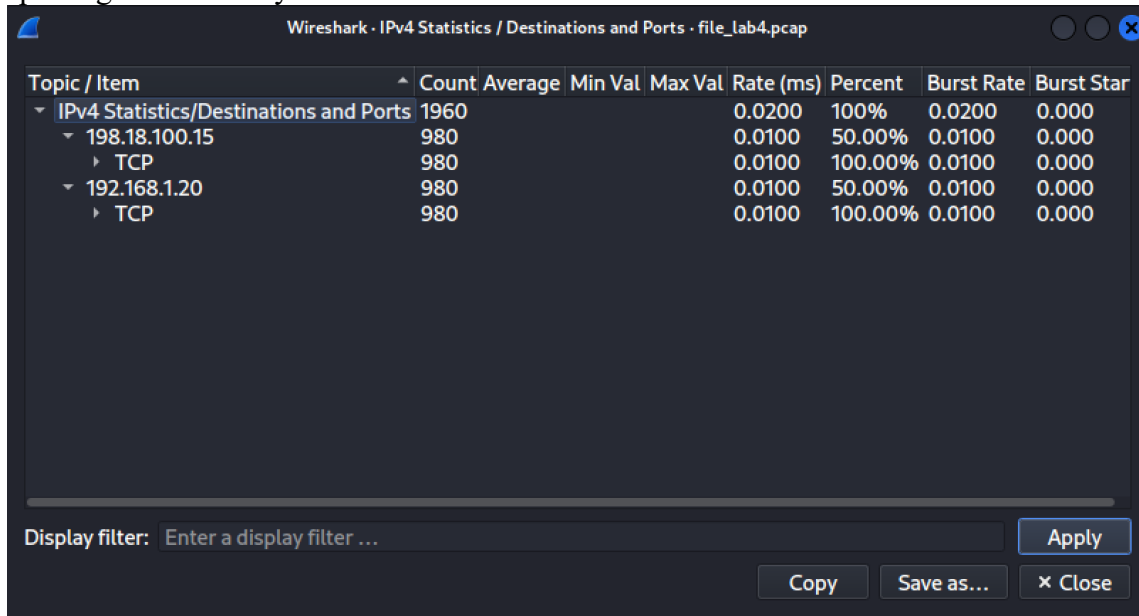
- IP: 198.18.100.15
- MAC: Unknown
- NIC Vendor: Unknown
- Hostname:
- OS: MacOS
- TTL: 64 (distance: 0)
- Latency: Unknown
- Open TCP Ports:
- Sent: 980 packets (39,200 Bytes)
- Received: 980 packets (39,200 Bytes)
- Incoming sessions: 4
- Outgoing sessions: 974

Case Panel

Filename	MD5
file_lab4.p	b9308be1

Buffered Frames to Parse:

5. Verified the details of Network Miner by acquiring Wireshark's *Statistics, Destinations and Ports* details. It shows 980 TCP packets were exchanged in both directions between two hosts by splitting traffic evenly.



Wireshark - IPv4 Statistics / Destinations and Ports - file_lab4.pcap

Topic / Item	Count	Average	Min Val	Max Val	Rate (ms)	Percent	Burst Rate	Burst Star
IPv4 Statistics/Destinations and Ports	1960				0.0200	100%	0.0200	0.000
198.18.100.15	980				0.0100	50.00%	0.0100	0.000
TCP	980				0.0100	100.00%	0.0100	0.000
192.168.1.20	980				0.0100	50.00%	0.0100	0.000
TCP	980				0.0100	100.00%	0.0100	0.000

Display filter: Enter a display filter ... Apply

Copy Save as... Close

Part -2

1. Data in *file_lab4.pcap* file shows the indications of Exploitation stage of the attack lifecycle in the Lockheed Martin Cyber Kill Chain. The investigation clearly indicates that the attacker 198.18.100.15 communicates through port 22 (SSH) and port 80 (HTTP) with the target host 192.168.1.20. The attacker was trying to get unauthorized access through port 22 (SSH), clearly indicates attempting brute force attack or vulnerability exploitation to gain access. Sametime port 80 (HTTP) may be used to initiate web-based exploitation. These activities showed the Exploitation phase, where the attackers leverage vulnerabilities in applications or services to establish unauthorized access on the target system (NIST SP 300-30, 2012).

2. From last week and this week packet capture indicates Confidentiality, Integrity and Availability (CIA Triangle) of data at a threat. It clearly shows that DDoS attack on last week's report and it will directly target the availability of data in the bank system by sending excessive HTTP GET requests to the bank web server. This week's analysis report shows the SSH exploitation that treats confidentiality and integrity of the bank system. This clearly indicates the exposure of sensitive data through unauthorized access.

Overwhelming the bank web server will not provide access to the authorized users/ bank customers to access their account online. This will directly affect the bank reputation, cause customer dissatisfaction, and lead to financial disruption. When the attacker successfully exploitation through SSH will provide administrative access to the attacker. Then the attacker can steal sensitive data from the banking system.

Part -3

1. SC-5 and AC-2 can be used as security controls to mitigate the risk of realizing each threat identified in part 2(2).

SC-5 Denial of Service Protection

SC-5 belongs to System and Communications Protection Family. This includes Restrict ability to attack other systems, Capacity, Bandwidth, and Redundancy, and Detection and monitoring. This control requires implementation of Intrusion Detection and Prevention Systems (IDS/IPS), traffic filtering to block abnormal traffic.

AC-2 Account Management

AC-2 belongs to Access Control Family. This includes Restriction on use of shared and group accounts, Privileged user accounts, and Disable accounts and more other controls. These controls require unique credentials and multifactor authentication (MFA) to the accounts to protect the system from unauthorized access.

2. SC-5 Denial of Service protection controls required to protect systems from DoS or DDoS attacks which directly impact to the service availability. The bank customers must be able to log in their account at any time they want, so we need to protect the system from Denial of Service attacks. If the legitimate customers not able to access their accounts will affect the bank reputation and lead to financial loss.

AC-2 Account Management controls required to protect the bank system from brute force attacks or exploitation to gain control of the bank network. By implementing account management, we can protect accounts from unauthorized access. Also, we need to have MFA to have more protection to the bank system to protect confidentiality and integrity.

Conclusion

This lab helps to cover the practical aspects of packet analysis using Network Miner and Wireshark, and how to use them to implement bank risk management processes using investigated data. The analysis of *file_lab4.pcap* confirmed that malicious traffic getting into bank internal system through SSH and HTTP communication between 198.18.100.15 and 192.168.1.20. Last week's analysis clearly indicates the DDoS disrupts the banking system and restricts the availability of the system to authorized users/ bank customers. These attacks exploited to compromise all CIA triangle aspects, confidentiality, integrity and availability.

SC-5 Denial of Service Protection and AC-2 Account Management from NIST SP 800-53 directly address the risks post by brute force attack and service disruption. They will provide layered protection to the banking system to protect confidentiality, integrity, and availability of banking network.

References

1. Easttom, C. (2022). *Computer security fundamentals* (5th ed.). Pearson IT Certification.
2. Shostack, A. (2014). *Threat modeling: Designing for security*. Wiley.
3. National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments (NIST SP 800-30 Rev. 1)*. U.S. Department of Commerce.
<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>
4. National Institute of Standards and Technology. (2018). *Risk management framework for information systems and organizations: A system life cycle approach for security and privacy (NIST SP 800-37 Rev. 2)*. U.S. Department of Commerce.
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-37r2.pdf>
5. National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations (NIST SP 800-53 Rev. 5)*. U.S. Department of Commerce.
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>